

False Positive Documentation

Kindly provide the answers for the following queries regarding the vulnerability.

1. Name of the Application

Pledgivo

2. Package ID/Version ID/Listing ID

Package ID: 0Hof600000000iHCAU · Version ID: 04tf60000000RdBlAAK (Pledgivo 1.2.4-1 (Managed - Released)) · Listing ID: not yet listed

3. Partner Name

CloudAlgo

4. Document Filing Date (YYYY-MM-DD)

2026-10-09

5. Target URL (Optional)

6. Review Date (In Case if app already undergone security review)

Repeat Step 7 to 10 in case of multiple Vulnerability – 23 vulnerabilities follow, one per Code Analyzer finding (Appendix A indexes them)

7. Vulnerability Name

ApexDangerousMethods — classes/donation/domain/DonationDesignations.cls:36 (R-001; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

8. Detected By

☐ Chimera

☒ PMD

☐ Security Review

☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

9. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Calling potentially dangerous method — reported by ApexDangerousMethods (pmd, Moderate) at `classes/donation/domain/DonationDesignations.cls:36`

WHY THE CLAIM IS FALSE

The claim that this call "opens the door to several attacks" by disabling CRUD security is false. The call switches off only FFLib's own trigger-layer assertion, `fflib_SObjectDomain.Configuration.EnforcingTriggerCRUDSecurity`, a library check that the vendored base class layers above the platform. It changes nothing about how the DML executes: every write that fires this domain still runs under Salesforce's own object permissions, field-level security and sharing, which no Apex call can disable. This domain only recomputes `Designation__c` fund totals when a `Donation_Designation__c` row changes. That object is a master-detail detail of the standard Opportunity, so a second-generation package cannot ship an object permission on it and `isCreateable()` is false for every user without Modify All Data; with the library check left on, FFLib throws `Permission to create an Donation_Designation__c denied.` on a rollup the user is entitled to trigger, and the fund total silently stops updating. The constructor is the only site and carries its reason in the `// doc:` comment above it.

SUPPORTING DETAIL

Configuration.disableTriggerCRUDSecurity() in a rollup domain constructor. The FFLib domain layer re-asserts `isCreateable()` on every record even when the DML is running in `SYSTEM_MODE`, which makes an internally-triggered rollup fail for any user who cannot directly create the rolled-up record. These two domains recompute totals only—`Designation__c` and recurring-donation aggregates—and the call scopes the opt-out to the FFLib trigger check alone. The DML itself still runs under the platform's rules; the platform's own CRUD, FLS and sharing enforcement is untouched. Without it, a non-admin donation write silently stops rolling up fund totals.

- **At this site:** Designation total rollup. Without the opt-out the rollup silently stops recomputing fund totals for non-admin users.
- **What the rule checks:** PMD's ApexDangerousMethods flags `Configuration.disableTriggerCRUDSecurity()`, which turns off FFLib's own CRUD assertion inside the trigger layer.

SOURCES

- https://docs.pmd-code.org/pmd-doc-7.26.0/pmd_rules_apex_security.html#apexdangerousmethods — "Checks against calling dangerous methods"; on `Configuration.disableTriggerCRUDSecurity()`: "Disabling CRUD security opens the door to several attacks and requires manual validation, which is unreliable."
- https://github.com/apex-enterprise-patterns/fflib-apex-common/blob/master/sfdx-source/apex-common/main/classes/fflib_SObjectDomain.cls — `Configuration.EnforcingTriggerCRUDSecurity` is documented as "True if the base class is checking the users CRUD requirements before invoking trigger methods"; `handleAfterInsert()` throws `DomainException('Permission to create an ' + name + ' denied.')` when it is on and `SObjectDescribe.isCreateable()` is false. It is a library check, not a platform setting.
- AGENTS.md, "Change Management — Locked Decisions Protocol": why a detail of a standard object cannot be granted by a 2GP permission set, so its field permissions are inert and `isCreateable()` is false for every non-admin user.

10. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — CLASSES/DONATION/DOMAIN/DONATIONDESIGNATIONS.CLS:36

```
33      */
34      public DonationDesignations(List<Donation_Designation__c> records) {
35          super(records);
» 36          Configuration.disableTriggerCRUDSecurity();
37      }
38
39      /**
```

EVIDENCE CHECKED

Both call sites are annotated in place. In `RecurringDonations` the call sits behind an explicit `suppressTriggerCrudCheck` flag rather than being unconditional. The wider reasoning—that field permissions are inert without object access on a master-detail detail object—is written up in the Change Management section of AGENTS.md and in the `EventTicketTypesSelector` class header.

11. Vulnerability Name

ApexDangerousMethods — `classes/donor/domain/Contacts.cls:52` (R-002; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

12. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors `AppExchange + Recommended:Security`, configuration `code-analyzer.yml`, target `base/`; 23 findings across 3 rules; source commit 36949d12.

13. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Calling potentially dangerous method — reported by ApexDangerousMethods (pmd, Moderate) at `classes/donor/domain/Contacts.cls:52`

WHY THE CLAIM IS FALSE

The claim is false for the same reason: The call switches off only FFLib's own trigger-layer assertion, `fflib_SObjectDomain.Configuration.EnforcingTriggerCRUDSecurity`, a library check that the vendored base class layers above the platform. It changes nothing about how the DML executes: every write that fires this domain still runs under Salesforce's own object permissions, field-level security and sharing, which no Apex call can disable. The call is guarded by `suppressTriggerCrudCheck`, which only `CampaignService`'s donor-rollup commit sets, saving the prior value and restoring it in a `finally`. That commit writes three rollup fields on the donor Contact (`Total_Donated__c`, `Gift_Count__c`, `Last_Donation_Date__c`) after a gift is finalized, in the transaction of whoever saved the gift, including the site guest user, who cannot hold Edit on Contact. The rollup values are computed server-side from the gift that was just committed; no caller-supplied value reaches the Contact, and the platform's own permission checks on the write are untouched.

SUPPORTING DETAIL

Configuration.disableTriggerCRUDSecurity() in a rollup domain constructor. The FFLib domain layer re-asserts `isCreateable()` on every record even when the DML is running in `SYSTEM_MODE`, which makes an internally-triggered rollup fail for any user who cannot directly create the rolled-up record. These two domains recompute totals only—`Designation__c` and recurring-donation aggregates—and the call scopes the opt-out to the FFLib trigger check alone. The DML itself still runs under the platform's rules; the platform's own CRUD, FLS and sharing enforcement is untouched. Without it, a non-admin donation write silently stops rolling up fund totals.

- **At this site:** Donor rollup (`Total_Donated__c`, `Gift_Count__c`, `Last_Donation_Date__c`), behind `suppressTriggerCrudCheck`, which only `CampaignService`'s rollup commit sets and restores in `finally`. Without it a staff user who can edit a donation but not a Contact cannot close a gift.
- **What the rule checks:** PMD's ApexDangerousMethods flags `Configuration.disableTriggerCRUDSecurity()`, which turns off FFLib's own CRUD assertion inside the trigger layer.

SOURCES

- https://docs.pmd-code.org/pmd-doc-7.26.0/pmd_rules_apex_security.html#apexdangerousmethods — "Checks against calling dangerous methods"; on `Configuration.disableTriggerCRUDSecurity()`: "Disabling CRUD security opens the door to several attacks and requires manual validation, which is unreliable."

- https://github.com/apex-enterprise-patterns/fliib-apex-common/blob/master/sfdx-source/apex-common/main/classes/fliib_SObjectDomain.cls — `Configuration.EnforcingTriggerCRUDSecurity` is documented as "True if the base class is checking the users CRUD requirements before invoking trigger methods"; `handleAfterInsert()` throws `DomainException('Permission to create an ' + name + ' denied.')` when it is on and `SObjectDescribe.isCreateable()` is false. It is a library check, not a platform setting.
- AGENTS.md, "Change Management — Locked Decisions Protocol": why a detail of a standard object cannot be granted by a 2GP permission set, so its field permissions are inert and `isCreateable()` is false for every non-admin user.

14. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — CLASSES/DONOR/DOMAIN/CONTACTS.CLS:52

```
49      */
50      public Contacts(List<Contact> records) {
51          super(records);
» 52          if (suppressTriggerCrudCheck) { Configuration.disableTriggerCRUDSecurity(); }
53      }
54
55      /**
```

EVIDENCE CHECKED

Both call sites are annotated in place. In `RecurringDonations` the call sits behind an explicit `suppressTriggerCrudCheck` flag rather than being unconditional. The wider reasoning—that field permissions are inert without object access on a master-detail detail object—is written up in the Change Management section of AGENTS.md and in the `EventTicketTypesSelector` class header.

15. Vulnerability Name

ApexDangerousMethods — `classes/recurring/domain/RecurringDonations.cls:61` (R-003; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

16. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors `AppExchange + Recommended:Security`, configuration `code-analyzer.yml`, target `base/`; 23 findings across 3 rules; source commit 36949d12.

17. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Calling potentially dangerous method — reported by ApexDangerousMethods (pmd, Moderate) at `classes/recurring/domain/RecurringDonations.cls:61`

WHY THE CLAIM IS FALSE

The claim is false for the same reason: The call switches off only FFLib's own trigger-layer assertion, `fflib_SObjectDomain.Configuration.EnforcingTriggerCRUDSecurity`, a library check that the vendored base class layers above the platform. It changes nothing about how the DML executes: every write that fires this domain still runs under Salesforce's own object permissions, field-level security and sharing, which no Apex call can disable. Here the call is not even unconditional. It runs only while the static `suppressTriggerCrudCheck` flag is true, and the sole code that sets the flag is the donor-portal path in `DonorPortalService` that updates a schedule on the donor's own behalf, which sets it immediately before the commit and clears it in the next statement. In every other transaction the FFLib assertion stays on. The donor is authorized by a verified access code before that path is reached, and the guest user it runs as cannot hold Edit on the object at all (a platform limit of the guest licence), which is exactly why the library check would otherwise block a legitimate update.

SUPPORTING DETAIL

Configuration.disableTriggerCRUDSecurity() in a rollup domain constructor. The FFLib domain layer re-asserts `isCreateable()` on every record even when the DML is running in `SYSTEM_MODE`, which makes an internally-triggered rollup fail for any user who cannot directly create the rolled-up record. These two domains recompute totals only — `Designation__c` and recurring-donation aggregates — and the call scopes the opt-out to the FFLib trigger check alone. The DML itself still runs under the platform's rules; the platform's own CRUD, FLS and sharing enforcement is untouched. Without it, a non-admin donation write silently stops rolling up fund totals.

- **At this site:** Same call, behind the explicit `suppressTriggerCrudCheck` flag rather than unconditional.
- **What the rule checks:** PMD's ApexDangerousMethods flags `Configuration.disableTriggerCRUDSecurity()`, which turns off FFLib's own CRUD assertion inside the trigger layer.

SOURCES

- https://docs.pmd-code.org/pmd-doc-7.26.0/pmd_rules_apex_security.html#apexdangerousmethods — "Checks against calling dangerous methods"; on `Configuration.disableTriggerCRUDSecurity()`: "Disabling CRUD security opens the door to several attacks and requires manual validation, which is unreliable."
- https://github.com/apex-enterprise-patterns/fflib-apex-common/blob/master/sfdx-source/apex-common/main/classes/fflib_SObjectDomain.cls — `Configuration.EnforcingTriggerCRUDSecurity` is documented as "True if the base class is checking the users CRUD requirements before invoking trigger methods"; `handleAfterInsert()` throws `DomainException('Permission to`

create an ' + name + ' denied.') when it is on and `SObjectDescribe.isCreateable()` is false. It is a library check, not a platform setting.

- AGENTS.md, "Change Management — Locked Decisions Protocol": why a detail of a standard object cannot be granted by a 2GP permission set, so its field permissions are inert and `isCreateable()` is false for every non-admin user.

18. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — CLASSES/RECURRING/DOMAIN/RECURRINGDONATIONS.CLS:61

```
58      */
59      public RecurringDonations(List<Recurring_Donation__c> records) {
60          super(records);
» 61          if (suppressTriggerCrudCheck) { Configuration.disableTriggerCRUDSecurity(); }
62      }
63
64      /**
```

EVIDENCE CHECKED

Both call sites are annotated in place. In `RecurringDonations` the call sits behind an explicit `suppressTriggerCrudCheck` flag rather than being unconditional. The wider reasoning—that field permissions are inert without object access on a master-detail detail object—is written up in the Change Management section of AGENTS.md and in the `EventTicketTypesSelector` class header.

19. Vulnerability Name

ProtectSensitiveData — objects/Campaign_Design__c/fields/Theme_Tokens_JSON__c.field-meta.xml:1 (R-004; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

20. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

21. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Theme_Tokens_JSON__c is a potential auth token in a custom object: Campaign_Design__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Campaign_Design__c/fields/Theme_Tokens_JSON__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on the substring *token*, and the field is a Long Text Area holding a JSON map of CSS custom-property overrides (design tokens such as a button colour or a heading font) for a fundraising page design. The service layer filters every key against a packaged catalog (Theme_Token__mdt) and rejects unsafe values before a page reads it. It is admin-edited presentation data on a per-design record; it authenticates nothing and could not be stored in a protected setting.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** CSS design-token overrides as JSON; *token* means a CSS custom property.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".

- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom metadata or protected custom settings. None of these fields holds a key.
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/objects/<Object>/fields/<Field>.field-meta.xml` — each flagged field's `<description>` and `<inlineHelpText>` state what it holds.

22. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/CAMPAIGN DESIGN_C/FIELDS/THEME_TOKENS_JSON__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
  2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
  3   <fullName>Theme_Tokens_JSON__c</fullName>
  4   <description>Advanced admin-only JSON of CSS token overrides beyond the named
color/style fields on this object. Only keys present in the packaged Theme_Token__mdt catalog are
honored — CampaignService.normalizeThemeTokensJson() strips anything else before a guest page ever
sees it. No arbitrary CSS injection is possible.</description>
```

EVIDENCE CHECKED

Each field's `<description>` in `base/main/default/objects/` says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in `docs/security/appexchange-security-review-readiness.md`), which is what the rule's remediation is for.

23. Vulnerability Name

ProtectSensitiveData — objects/Donation_Designation__c/fields/Designation__c.field-meta.xml:1 (R-005; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

24. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

25. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Designation__c is a potential auth token in a custom object: Donation_Designation__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Donation_Designation__c/fields/Designation__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on the substring *sign* inside *Designation*, the fundraising term for the fund or program a gift is earmarked to. The field is a lookup to a Designation__c record on the row that records one split of a gift. A relationship field holds a record Id, not a secret.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Lookup to the fund a gift split supports; matches on *sign*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

26. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/DONATION_DESIGNATION__C/FIELDS/DESIGNATION__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Designation__c</fullName>
   4   <description>The fund or program this split of the donation supports.</description>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

27. Vulnerability Name

ProtectSensitiveData — objects/Donation_Staging__c/fields/Access_Token__c.field-meta.xml:1 (R-006; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

28. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

29. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Access_Token__c is a potential auth token in a custom object: Donation_Staging__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Donation_Staging__c/fields/Access_Token__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this value should be stored in a protected custom setting is false because it is not an org-wide secret and no setting could hold it: it is a per-record capability token minted server-side for one guest checkout. It is a 256-bit random value (SecureTokens.opaque(), 64 hex characters) written to a unique external-Id field on the staging row, scopes three guest actions to that single row, cannot address any other record, and dies with the row when the checkout completes or the staging retention job purges it. Its entropy, expiry, single-use, revocation and guest-FLS properties are written in the field's <description> and tabulated in FP-16 of the readiness document. Holding it in a protected setting would make it org-wide, which is the opposite of the control it provides.

SUPPORTING DETAIL

Per-record capability tokens, idempotency keys and SHA-256 hashes. None of these is an org-wide secret, and none could live in a setting: each is per-record transactional state. Donation_Staging__c.Access_Token__c is a 256-bit random capability token minted server-side for one guest checkout; it scopes three guest actions to that single staging row, cannot read any other record, and dies with the row. Idempotency_Key__c on Donation_Staging__c and Guest_Request__c is a client-generated request identifier whose only job is to make a double-submit reuse the first attempt; possessing one grants nothing, and the unique index on it is the race backstop.

Portal_Access_Token__c.Code_Hash__c and Session_Hash__c hold the SHA-256 of the emailed sign-in code and of the browser session token respectively — the raw value is never stored, the code hash is nulled the moment the code is redeemed, and the session hash is a unique external Id so a per-request lookup is selective. Storing hashes rather than values is precisely the control the rule is asking for.

- **At this site:** 256-bit random capability token scoped to one staging row; properties in FP-16.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *token*, *key* or *hash*, expecting a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." A protected setting is org-wide configuration; these fields are per-record transaction state, so the remediation cannot apply.

- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — protected custom settings and protected custom metadata are the module's stores for "API keys or other secret keys"; a per-checkout nonce or a hash of a one-time code is neither.
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/classes/donor/service/DonorPortalService.cls — `Code_Hash__c = hashToken( rawCode )` on issue, `Code_Hash__c = null` on redemption ("single-use: replay fails structurally"), `Session_Hash__c = hashToken( sessionToken )`; the raw values are never written.
- docs/security/appexchange-security-review-readiness.md, FP-16 — the token table: entropy, expiry, single-use, revocation and guest -FLS posture for every URL-borne token.

30. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/DONATION_STAGING__C/FIELDS/ACCESS_TOKEN__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
  2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
  3   <fullName>Access_Token__c</fullName>
  4   <label>Access Token</label>
```

EVIDENCE CHECKED

The five properties of each URL-borne token (entropy, expiry, single-use, revocation, guest FLS posture) are written in the field `<description>` and tabulated in FP-16 of docs/security/appexchange-security-review-readiness.md. `SecureTokens.opaque()` mints the staging token; `DonorPortalService` writes only hashes to `Portal_Access_Token__c`.

31. Vulnerability Name

ProtectSensitiveData — objects/Donation_Staging__c/fields/Idempotency_Key__c.field-meta.xml:1 (R-007; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

32. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

33. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Idempotency_Key__c is a potential auth token in a custom object: Donation_Staging__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Donation_Staging__c/fields/Idempotency_Key__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim is false because the field holds a client-generated identifier for one ticket-checkout attempt, not a credential: its only job is to make a double-submit reuse the first attempt instead of charging twice. Possessing the value grants nothing, it is never used to authorise a read or a write, and the unique external-Id index on it is the race backstop. It is per-record transaction state and cannot live in an org-wide setting.

SUPPORTING DETAIL

Per-record capability tokens, idempotency keys and SHA-256 hashes. None of these is an org-wide secret, and none could live in a setting: each is per-record transactional state. Donation_Staging__c.Access-Token__c is a 256-bit random capability token minted server-side for one guest checkout; it scopes three guest actions to that single staging row, cannot read any other record, and dies with the row. Idempotency_Key__c on Donation_Staging__c and Guest_Request__c is a client-generated request identifier whose only job is to make a double-submit reuse the first attempt; possessing one grants nothing, and the unique index on it is the race backstop.

Portal_Access-Token__c.Code_Hash__c and Session_Hash__c hold the SHA-256 of the emailed sign-in code and of the browser session token respectively — the raw value is never stored, the code hash is nulled the moment the code is redeemed, and the session hash is a unique external Id so a per-request lookup is selective. Storing hashes rather than values is precisely the control the rule is asking for.

- **At this site:** Client-generated ticket-checkout attempt id; unique index is the double-submit backstop.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *token*, *key* or *hash*, expecting a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." A protected setting is org-wide configuration; these fields are per-record transaction state, so the remediation cannot apply.
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — protected custom settings and protected custom metadata are the module's stores for "API keys or other secret keys"; a per-checkout nonce or a hash of a one-time code is neither.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/classes/donor/service/DonorPortalService.cls — `Code_Hash__c = hashToken ( rawCode )` on issue, `Code_Hash__c = null` on redemption ("single-use: replay fails structurally"), `Session_Hash__c = hashToken ( sessionToken )`; the raw values are never written.
- docs/security/appexchange-security-review-readiness.md, FP-16 — the token table: entropy, expiry, single-use, revocation and guest -FLS posture for every URL-borne token.

34. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/DONATION_STAGING__C/FIELDS/IDEMPOTENCY_KEY__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Idempotency_Key__c</fullName>
   4   <label>Idempotency Key</label>
```

EVIDENCE CHECKED

The five properties of each URL-borne token (entropy, expiry, single-use, revocation, guest FLS posture) are written in the field `<description>` and tabulated in FP-16 of docs/security/appexchange-security-review-readiness.md. `SecureTokens.opaque()` mints the staging token; `DonorPortalService` writes only hashes to `Portal_Access_Token__c`.

35. Vulnerability Name

ProtectSensitiveData — objects/Guest_Request__c/fields/Idempotency_Key__c.field-meta.xml:1 (R-008; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

36. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

37. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Idempotency_Key__c is a potential auth token in a custom object: Guest_Request__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Guest_Request__c/fields/Idempotency_Key__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim is false for the same reason: the field is a client-generated request identifier on a queued donor request (a refund request, an attendee-naming request) so that a double-click cannot queue the same work twice. It authorises nothing; the request itself is authorised by the donor's verified portal access code before the row is created. A per-request nonce cannot be an org-wide protected setting.

SUPPORTING DETAIL

Per-record capability tokens, idempotency keys and SHA-256 hashes. None of these is an org-wide secret, and none could live in a setting: each is per-record transactional state. Donation_Staging__c.Access-Token__c is a 256-bit random capability token minted server-side for one guest checkout; it scopes three guest actions to that single staging row, cannot read any other record, and dies with the row. Idempotency_Key__c on Donation_Staging__c and Guest_Request__c is a client-generated request identifier whose only job is to make a double-submit reuse the first attempt; possessing one grants nothing, and the unique index on it is the race backstop.

Portal_Access-Token__c.Code_Hash__c and Session_Hash__c hold the SHA-256 of the emailed sign-in code and of the browser session token respectively — the raw value is never stored, the code hash is nulled the moment the code is redeemed, and the session hash is a unique external Id so a per-request lookup is selective. Storing hashes rather than values is precisely the control the rule is asking for.

- **At this site:** Client-generated request id so a double-click cannot queue the same work twice.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *token*, *key* or *hash*, expecting a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." A protected setting is org-wide configuration; these fields are per-record transaction state, so the remediation cannot apply.
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — protected custom settings and protected custom metadata are the module's stores for "API keys or other secret keys"; a per-checkout nonce or a hash of a one-time code is neither.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/classes/donor/service/DonorPortalService.cls — `Code_Hash__c = hashToken( rawCode )` on issue, `Code_Hash__c = null` on redemption ("single-use: replay fails structurally"), `Session_Hash__c = hashToken( sessionToken )`; the raw values are never written.
- docs/security/appexchange-security-review-readiness.md, FP-16 — the token table: entropy, expiry, single-use, revocation and guest -FLS posture for every URL-borne token.

38. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/GUEST_REQUEST__C/FIELDS/IDEMPOTENCY_KEY__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Idempotency_Key__c</fullName>
   4   <description>Identifies one logical request so a double-submit cannot queue the same
work twice. Unique: the database index is what settles the race when two clicks arrive at once,
rather than a lookup that both could miss.</description>
```

EVIDENCE CHECKED

The five properties of each URL-borne token (entropy, expiry, single-use, revocation, guest FLS posture) are written in the field `<description>` and tabulated in FP-16 of docs/security/appexchange-security-review-readiness.md.

`SecureTokens.opaque()` mints the staging token; `DonorPortalService` writes only hashes to `Portal_Access-Token__c`.

39. Vulnerability Name

ProtectSensitiveData — objects/Payment_Account__c/fields/Publishable_Key__c.field-meta.xml:1 (R-009; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

40. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

41. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Publishable_Key__c is a potential auth token in a custom object: Payment_Account__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Payment_Account__c/fields/Publishable_Key__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field holds a secret that belongs in a protected setting is false: it holds Stripe's publishable key (pk___), which Stripe documents as safe to expose and designed to be included in front-end code. It can only identify the account and create payment tokens from card details the donor is typing; it cannot create charges, issue refunds or read account data. The package sends it to every donor's browser by construction, because Stripe.js cannot mount the payment form without it. A protected setting exists to hide a value from the subscriber; this value is published on every donation page on purpose. The secret and restricted keys that do authorise charges and refunds are never in any field.

SUPPORTING DETAIL

Fields that hold a Named Credential's name, not a key. Stripe_Donor_Restricted_Key__c and Stripe_Admin_Restricted_Key__c are Text(80) fields holding the ****API name**** of a Named Credential the subscriber admin built by hand in Setup, and Apex consumes them as 'callout:' + name. The key itself is inside the Named Credential and is never readable from Apex, a field, or the UI. The fields are per-Payment-Account rather than org-wide because one org can run several gateway accounts (for example one per legal entity), which a hierarchy setting cannot model. Publishable_Key__c holds Stripe's publishable key, which Stripe designs to be embedded in browser-side code and is sent to every donor's browser by construction; it authorises nothing on its own.

- **At this site:** Stripe publishable key — designed to be sent to the browser; secret key is never in a field.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *key*, expecting the value to be a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- <https://docs.stripe.com/keys> — the publishable key (pk___) is "Safe to expose: Yes ... It can identify your account and create tokens or PaymentMethods from payment details, but it can't perform sensitive operations such as creating charges or reading account data. You can include it in front-end code"; restricted and secret keys are not safe to expose and "Don't put keys in source code or configuration files."
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — Named Credentials are "a mechanism for securely managing authentication values for external providers and services"; the module's remediation for an API key is a Named Credential or a protected setting, which is exactly where the key lives here.

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_callouts_named_credentials.htm — Apex callouts through Named Credentials (`callout:<name>`), the construction `StripeGateway.cls` uses (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/classes/payment/gateway/StripeGateway.cls` — `this.donorEndpoint = 'callout:' + acct.Stripe_Donor_Restricted_Key__c;` and the matching admin line: the field value is a Named Credential name.
- `docs/security/appexchange-security-review-readiness.md`, FP-4 — the Named-Credentials-only rule and the reviewer-facing write-up.

42. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/PAYMENT_ACCOUNT__C/FIELDS/PUBLISHABLE_KEY__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Publishable_Key__c</fullName>
   4   <description>Client-side publishable key for this account, sent to the browser-side
payment element/iframe. Publishable keys are designed by the gateway to be exposed client-side and
are not secret ¶; unlike the secret key, which stays only in the account's Named Credential.
</description>
```

EVIDENCE CHECKED

Both restricted-key fields say in their `<description>` that they hold a name and that an unrestricted secret key is not an acceptable value for the credential behind it; `StripeGateway.cls` builds the endpoint as `'callout:' + acct.Stripe_Donor_Restricted_Key__c`. AGENTS.md Rule 9 makes this the required pattern, and FP-4 in `docs/security/appexchange-security-review-readiness.md` documents it for the reviewer.

43. Vulnerability Name

ProtectSensitiveData — objects/Payment_Account__c/fields/Stripe_Admin_Restricted_Key__c.field-meta.xml:1 (R-010; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

44. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

45. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Stripe_Admin_Restricted_Key__c is a potential auth token in a custom object: Payment_Account__c — reported by ProtectSensitiveData (pmd, Moderate) at

objects/Payment_Account__c/fields/Stripe_Admin_Restricted_Key__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field is "a potential auth token" that should move to a protected setting is false: the field is a Text(80) that holds the API name of a Named Credential, not a key. The subscriber administrator builds that Named Credential by hand in Setup and pastes the restricted key into it; the package consumes the field as 'callout:' + name and can never read the key back, which is exactly the Named Credential pattern the rule's remediation guidance describes. The field's <description> states that it holds a name and that an unrestricted secret key is not an acceptable value for the credential behind it. It is per payment account rather than org-wide because one organisation can run several gateway accounts, which a hierarchy setting cannot model.

SUPPORTING DETAIL

Fields that hold a Named Credential's name, not a key. Stripe_Donor_Restricted_Key__c and Stripe_Admin_Restricted_Key__c are Text(80) fields holding the **API name** of a Named Credential the subscriber admin built by hand in Setup, and Apex consumes them as 'callout:' + name. The key itself is inside the Named Credential and is never readable from Apex, a field, or the UI. The fields are per-Payment-Account rather than org-wide because one org can run several gateway accounts (for example one per legal entity), which a hierarchy setting cannot model. Publishable_Key__c holds Stripe's publishable key, which Stripe designs to be embedded in browser-side code and is sent to every donor's browser by construction; it authorises nothing on its own.

- **At this site:** Text(80): API name of the Named Credential holding the back-office restricted key.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *key*, expecting the value to be a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- <https://docs.stripe.com/keys> — the publishable key (pk_...) is "Safe to expose: Yes ... It can identify your account and create tokens or PaymentMethods from payment details, but it can't perform sensitive operations such as creating charges or reading account data. You can include it in front-end code"; restricted and secret keys are not safe to expose and "Don't put keys in source code or configuration files."
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — Named Credentials are "a mechanism for securely managing authentication values for external providers and services"; the module's remediation for an API key is a Named Credential or a protected setting, which is exactly where the key lives here.

- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_callouts_named_credentials.htm — Apex callouts through Named Credentials (`callout:<name>`), the construction `StripeGateway.cls` uses (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/classes/payment/gateway/StripeGateway.cls` — `this.donorEndpoint = 'callout:' + acct.Stripe_Donor_Restricted_Key__c;` and the matching admin line: the field value is a Named Credential name.
- `docs/security/appexchange-security-review-readiness.md`, FP-4 — the Named-Credentials-only rule and the reviewer-facing write-up.

46. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/PAYMENT_ACCOUNT__C/FIELDS/STRIPE_ADMIN_RESTRICTED_KEY__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
  2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
  3   <fullName>Stripe_Admin_Restricted_Key__c</fullName>
  4   <description>API name of the Named Credential holding this account's back-office
gateway key, used only by staff-side operations: staff-issued refunds, the refund and dispute
reconcilers, the orphan-payment sweep, off-session recurring renewals, and Test connection. Never
granted to a site guest user. The credential must hold a RESTRICTED key scoped to those operations.
A full unrestricted secret key is not an acceptable value: the setup guide probes this credential
(probeAdminKeyScope) and grades the account red until the key is refused a call outside that scope,
so an account running a full secret key can never reach "Ready to take payments". This
field stores a credential API NAME only, never a key: the key itself lives on the Named Credential,
per the platform's Named Credential-only secrets policy.</description>
```

EVIDENCE CHECKED

Both restricted-key fields say in their `<description>` that they hold a name and that an unrestricted secret key is not an acceptable value for the credential behind it; `StripeGateway.cls` builds the endpoint as `'callout:' + acct.Stripe_Donor_Restricted_Key__c`. AGENTS.md Rule 9 makes this the required pattern, and FP-4 in `docs/security/appexchange-security-review-readiness.md` documents it for the reviewer.

47. Vulnerability Name

ProtectSensitiveData — objects/Payment_Account__c/fields/Stripe_Donor_Restricted_Key__c.field-meta.xml:1 (R-011; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

48. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

49. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Stripe_Donor_Restricted_Key__c is a potential auth token in a custom object: Payment_Account__c — reported by ProtectSensitiveData (pmd, Moderate) at

objects/Payment_Account__c/fields/Stripe_Donor_Restricted_Key__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim is false for the same reason: the field is a Text(80) holding the API name of the Named Credential that carries the charge-only restricted key, consumed as 'callout:' + acct.Stripe_Donor_Restricted_Key__c in StripeGateway.cls. The key itself lives only inside the Named Credential the administrator built in Setup and is not readable from Apex, from the field or from any UI. Moving the field to a protected setting would move a credential name, not a secret, and would lose the per-account scope.

SUPPORTING DETAIL

Fields that hold a Named Credential's name, not a key. Stripe_Donor_Restricted_Key__c and Stripe_Admin_Restricted_Key__c are Text(80) fields holding the ****API name**** of a Named Credential the subscriber admin built by hand in Setup, and Apex consumes them as 'callout:' + name. The key itself is inside the Named Credential and is never readable from Apex, a field, or the UI. The fields are per-Payment-Account rather than org-wide because one org can run several gateway accounts (for example one per legal entity), which a hierarchy setting cannot model. Publishable_Key__c holds Stripe's publishable key, which Stripe designs to be embedded in browser-side code and is sent to every donor's browser by construction; it authorises nothing on its own.

- **At this site:** Text(80): API name of the Named Credential holding the charge-only restricted key.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *key*, expecting the value to be a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- <https://docs.stripe.com/keys> — the publishable key (pk_...) is "Safe to expose: Yes ... It can identify your account and create tokens or PaymentMethods from payment details, but it can't perform sensitive operations such as creating charges or reading account data. You can include it in front-end code"; restricted and secret keys are not safe to expose and "Don't put keys in source code or configuration files."
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — Named Credentials are "a mechanism for securely managing authentication values for external providers and services"; the module's remediation for an API key is a Named Credential or a protected setting, which is exactly where the key lives here.
- https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_callouts_named_credentials.htm — Apex callouts through Named Credentials (callout:<name>), the construction StripeGateway.cls uses (page could not be retrieved while th

is document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).

- `base/main/default/classes/payment/gateway/StripeGateway.cls` — `this.donorEndpoint = 'callout:' + acct.Stripe_Donor_Restricted_Key__c;` and the matching admin line: the field value is a Named Credential name.
- `docs/security/appexchange-security-review-readiness.md`, FP-4 — the Named-Credentials-only rule and the reviewer-facing write-up.

50. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/PAYMENT_ACCOUNT__C/FIELDS/STRIPE_DONOR_RESTRICTED_KEY__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
  2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
  3   <fullName>Stripe_Donor_Restricted_Key__c</fullName>
  4   <description>API name of the Named Credential that holds this account's
RESTRICTED, charge-only key, used by every donor-facing operation: creating customers, payment
intents, setup intents, attaching or reading payment methods, and re-reading a payment intent to
confirm its outcome. It needs Write on Stripe's Payment Intents, Setup Intents, Customers and
Payment Methods permissions and nothing else: that last read expands the charge and its balance
transaction, and Stripe fills them in on the Payment Intents permission alone. It must carry no
Charges and Refunds permission (only Write on that row can refund, and None is all the donation
form needs) nor any Payment Disputes permission &#8212; this is the credential the Experience Cloud
site guest user is granted. This field stores a credential API NAME only, never a key: the key
itself lives on the Named Credential, per the platform's Named Credential-only secrets policy.
</description>
```

EVIDENCE CHECKED

Both restricted-key fields say in their `<description>` that they hold a name and that an unrestricted secret key is not an acceptable value for the credential behind it; `StripeGateway.cls` builds the endpoint as `'callout:' + acct.Stripe_Donor_Restricted_Key__c`. AGENTS.md Rule 9 makes this the required pattern, and FP-4 in `docs/security/appexchange-security-review-readiness.md` documents it for the reviewer.

51. Vulnerability Name

ProtectSensitiveData — objects/Portal_Access_Token__c/fields/Code_Hash__c.field-meta.xml:1 (R-012; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

52. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

53. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Code_Hash__c is a potential auth token in a custom object: Portal_Access_Token__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Portal_Access_Token__c/fields/Code_Hash__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim is false because the field stores the SHA-256 hash of the emailed sign-in code, never the code itself: DonorPortalService writes Code_Hash__c = hashToken(rawCode) when a code is issued and sets Code_Hash__c = null the moment it is redeemed, so a stored value can neither reveal the code nor be replayed. Storing a hash in place of a secret is the control the rule exists to encourage, and a per-donor one-time code could not be an org-wide protected setting.

SUPPORTING DETAIL

Per-record capability tokens, idempotency keys and SHA-256 hashes. None of these is an org-wide secret, and none could live in a setting: each is per-record transactional state. Donation_Staging__c.Access_Token__c is a 256-bit random capability token minted server-side for one guest checkout; it scopes three guest actions to that single staging row, cannot read any other record, and dies with the row. Idempotency_Key__c on Donation_Staging__c and Guest_Request__c is a client-generated request identifier whose only job is to make a double-submit reuse the first attempt; possessing one grants nothing, and the unique index on it is the race backstop.

Portal_Access_Token__c.Code_Hash__c and Session_Hash__c hold the SHA-256 of the emailed sign-in code and of the browser session token respectively — the raw value is never stored, the code hash is nulled the moment the code is redeemed, and the session hash is a unique external Id so a per-request lookup is selective. Storing hashes rather than values is precisely the control the rule is asking for.

- **At this site:** SHA-256 of the emailed sign-in code, nulled on redemption; the code itself is never stored.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *token*, *key* or *hash*, expecting a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." A protected setting is org-wide configuration; these fields are per-record transaction state, so the remediation cannot apply.
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — protected custom settings and protected custom metadata are the module's stores for "API keys or other secret keys"; a per-checkout nonce or a hash of a one-time code is neither.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/classes/donor/service/DonorPortalService.cls — `Code_Hash__c = hashToken( rawCode)` on issue, `Code_Hash__c = null` on redemption ("single-use: replay fails structurally"), `Session_Hash__c = hashToken( sessionToken)`; the raw values are never written.
- docs/security/appexchange-security-review-readiness.md, FP-16 — the token table: entropy, expiry, single-use, revocation and guest -FLS posture for every URL-borne token.

54. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/PORTAL_ACCESS_TOKEN__C/FIELDS/CODE_HASH__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Code_Hash__c</fullName>
   4   <description>SHA-256 hex of the emailed sign-in code. Nulled out the moment the code
is redeemed, so a replayed copy of an already-used code fails structurally — there is no hash left
to compare against, rather than relying on Status alone to reject it.</description>
```

EVIDENCE CHECKED

The five properties of each URL-borne token (entropy, expiry, single-use, revocation, guest FLS posture) are written in the field `<description>` and tabulated in FP-16 of docs/security/appexchange-security-review-readiness.md.

`SecureTokens.opaque()` mints the staging token; `DonorPortalService` writes only hashes to `Portal_Access-Token__c`.

55. Vulnerability Name

ProtectSensitiveData — objects/Portal_Access_Token__c/fields/Session_Hash__c.field-meta.xml:1 (R-013; pmd, Moderate; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

56. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

57. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Session_Hash__c is a potential auth token in a custom object: Portal_Access_Token__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Portal_Access_Token__c/fields/Session_Hash__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim is false because the field stores the SHA-256 hash of the donor's browser session token (Session_Hash__c = hashToken(sessionToken)), never the token: the raw value exists only in the donor's browser, a per-request lookup compares hashes (PortalAccessTokensSelector selects on Session_Hash__c = :sessionHash), and the unique external-Id index keeps that lookup selective. The row expires on the configured session TTL and is revoked by deletion. A hash of a per-session value is not a secret and cannot be an org-wide setting.

SUPPORTING DETAIL

Per-record capability tokens, idempotency keys and SHA-256 hashes. None of these is an org-wide secret, and none could live in a setting: each is per-record transactional state. Donation_Staging__c.Access_Token__c is a 256-bit random capability token minted server-side for one guest checkout; it scopes three guest actions to that single staging row, cannot read any other record, and dies with the row. Idempotency_Key__c on Donation_Staging__c and Guest_Request__c is a client-generated request identifier whose only job is to make a double-submit reuse the first attempt; possessing one grants nothing, and the unique index on it is the race backstop.

Portal_Access_Token__c.Code_Hash__c and Session_Hash__c hold the SHA-256 of the emailed sign-in code and of the browser session token respectively — the raw value is never stored, the code hash is nulled the moment the code is redeemed, and the session hash is a unique external Id so a per-request lookup is selective. Storing hashes rather than values is precisely the control the rule is asking for.

- **At this site:** SHA-256 of the browser session token, unique external Id; the token itself is never stored.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name contains *token*, *key* or *hash*, expecting a secret that belongs in a Protected Custom Setting or Protected Custom Metadata.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." A protected setting is org-wide configuration; these fields are per-record transaction state, so the remediation cannot apply.
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — protected custom settings and protected custom metadata are the module's stores for "API keys or other secret keys"; a per-checkout nonce or

a hash of a one-time code is neither.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/classes/donor/service/DonorPortalService.cls — `Code_Hash__c = hashToken( rawCode)` on issue, `Code_Hash__c = null` on redemption ("single-use: replay fails structurally"), `Session_Hash__c = hashToken( sessionToken)`; the raw values are never written.
- docs/security/appexchange-security-review-readiness.md, FP-16 — the token table: entropy, expiry, single-use, revocation and guest -FLS posture for every URL-borne token.

58. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/PORTAL_ACCESS_TOKEN__C/FIELDS/SESSION_HASH__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Session_Hash__c</fullName>
   4   <description>SHA-256 hex of the browser session token, written once at code redemption
and matched on every portal call. Never holds the raw token. Unique External Id: the index makes
the per-request lookup selective, and uniqueness stops a hash collision ever resolving two donors.
</description>
```

EVIDENCE CHECKED

The five properties of each URL-borne token (entropy, expiry, single-use, revocation, guest FLS posture) are written in the field `<description>` and tabulated in FP-16 of docs/security/appexchange-security-review-readiness.md.

`SecureTokens.opaque()` mints the staging token; `DonorPortalService` writes only hashes to `Portal_Access-Token__c`.

59. Vulnerability Name

ProtectSensitiveData — objects/Recurring_Designation__c/fields/Designation__c.field-meta.xml:1 (R-014; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

60. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

61. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Designation__c is a potential auth token in a custom object: Recurring_Designation__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Recurring_Designation__c/fields/Designation__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *sign* inside *Designation*. The field is a lookup to the fund a recurring gift split supports, on the junction object between a recurring schedule and its funds. It is a record Id.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Lookup to the fund a recurring split supports; matches on *sign*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

62. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/RECURRING_DESIGNATION__C/FIELDS/DESIGNATION__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Designation__c</fullName>
   4   <description>The fund or program this split of the recurring schedule supports.
</description>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

63. Vulnerability Name

ProtectSensitiveData — objects/Recurring_Donation__c/fields/Designation__c.field-meta.xml:1 (R-015; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

64. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

65. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Designation__c is a potential auth token in a custom object: Recurring_Donation__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Recurring_Donation__c/fields/Designation__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *sign* inside *Designation*. The field is the single-fund lookup on a recurring schedule, used when the schedule is not split across several funds. It is a record Id.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Single-fund lookup on a recurring schedule; matches on *sign*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

66. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/RECURRING_DONATION__C/FIELDS/DESIGNATION__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Designation__c</fullName>
   4   <description>Optional single-fund program designation for this schedule. Multi-fund
schedules instead use Recurring_Designation__c child records, but a single-fund schedule always
also stamps this lookup for simple reporting.</description>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

67. Vulnerability Name

ProtectSensitiveData — objects/Recurring_Donation__c/fields/Re_Auth_Link_Sent_At__c.field-meta.xml:1
(R-016; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

68. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

69. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Re_Auth_Link_Sent_At__c is a potential auth token in a custom object: Recurring_Donation__c — reported by ProtectSensitiveData (pmd, Moderate) at

objects/Recurring_Donation__c/fields/Re_Auth_Link_Sent_At__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *auth* inside *Re_Auth*, which here means re-authentication of a card payment, not an API credential. The field is a Date/Time recording when the donor was last emailed a reminder to complete 3-D Secure on-session for a renewal, so the reminder is not sent twice. A timestamp authorises nothing.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Timestamp of the last 3-D Secure reminder email; matches on *auth*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange.xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".

- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom metadata or protected custom settings. None of these fields holds a key.
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/objects/<Object>/fields/<Field>.field-meta.xml` — each flagged field's `<description>` and `<inlineHelpText>` state what it holds.

70. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/RECURRING_DONATION__C/FIELDS/RE_AUTH_LINK_SENT_AT__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Re_Auth_Link_Sent_At__c</fullName>
   4   <description>When a re-authentication link was last emailed to the donor after
Re_Auth_Required__c was set, so the reminder isn't resent on every batch run.</description>
```

EVIDENCE CHECKED

Each field's `<description>` in `base/main/default/objects/` says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in `docs/security/appexchange-security-review-readiness.md`), which is what the rule's remediation is for.

71. Vulnerability Name

ProtectSensitiveData — objects/Recurring_Donation__c/fields/Re_Auth_Required__c.field-meta.xml:1 (R-017; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

72. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

73. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Re_Auth_Required__c is a potential auth token in a custom object: Recurring_Donation__c — reported by ProtectSensitiveData (pmd, Moderate) at objects/Recurring_Donation__c/fields/Re_Auth_Required__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *auth* inside *Re_Auth*. The field is a Checkbox that marks a recurring schedule whose next renewal needs the donor to complete 3-D Secure on-session; it is set from the payment gateway's decline reason and cleared once the donor completes the challenge. A boolean flag is not a secret.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Checkbox: the donor must complete 3-D Secure on-session; matches on *auth*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange.xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".

- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom metadata or protected custom settings. None of these fields holds a key.
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/objects/<Object>/fields/<Field>.field-meta.xml` — each flagged field's `<description>` and `<inlineHelpText>` state what it holds.

74. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/RECURRING_DONATION__C/FIELDS/RE_AUTH_REQUIRED__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Re_Auth_Required__c</fullName>
   4   <label>Re-Auth Required</label>
```

EVIDENCE CHECKED

Each field's `<description>` in `base/main/default/objects/` says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in `docs/security/appexchange-security-review-readiness.md`), which is what the rule's remediation is for.

75. Vulnerability Name

ProtectSensitiveData — objects/Settings__c/fields/Default_Designation__c.field-meta.xml:1 (R-018; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

76. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

77. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Default_Designation__c is a potential auth token in the object: Settings__c with public visibility — reported by ProtectSensitiveData (pmd, Moderate) at objects/Settings__c/fields/Default_Designation__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *sign* inside *Designation*. The field is an 18-character Text holding the record Id of the fallback fund a gift is credited to when the donor picks none; it is Text only because a hierarchy custom setting cannot declare a lookup. It is edited by an administrator in the Settings console and holds nothing secret.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** 18-character Id of the fallback fund, stored as text because a Custom Setting cannot hold a lookup; matches on *sign*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange.xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".

- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom metadata or protected custom settings. None of these fields holds a key.
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/objects/<Object>/fields/<Field>.field-meta.xml` — each flagged field's `<description>` and `<inlineHelpText>` state what it holds.

78. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/SETTINGS__C/FIELDS/DEFAULT_DESIGNATION__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Default_Designation__c</fullName>
   4   <inlineHelpText>18-character Id of the fund/designation to credit when a donor does
not choose one. Leave blank for no default.</inlineHelpText>
```

EVIDENCE CHECKED

Each field's `<description>` in `base/main/default/objects/` says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in `docs/security/appexchange-security-review-readiness.md`), which is what the rule's remediation is for.

79. Vulnerability Name

ProtectSensitiveData — objects/Settings__c/fields/Email_Signature__c.field-meta.xml:1 (R-019; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

80. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

81. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Email_Signature__c is a potential auth token in the object: Settings__c with public visibility — reported by ProtectSensitiveData (pmd, Moderate) at objects/Settings__c/fields/Email_Signature__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *sign* inside *Signature*, which here is the sign-off line printed above the footer of every outbound email (for example "The Riverside Foundation team"). It is a short display string an administrator edits, seeded at install from the organisation name, and is sent to every donor by design.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Sign-off line printed above the footer of every outbound email.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

82. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/SETTINGS__C/FIELDS/EMAIL_SIGNATURE__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Email_Signature__c</fullName>
   4   <description>Sign-off line rendered above the footer on every outbound transactional
email.</description>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

83. Vulnerability Name

ProtectSensitiveData — objects/Settings__c/fields/Portal_Token_TTL_Hours__c.field-meta.xml:1 (R-020; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

84. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

85. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Portal_Token_TTL_Hours__c is a potential auth token in the object: Settings__c with public visibility — reported by ProtectSensitiveData (pmd, Moderate) at objects/Settings__c/fields/Portal_Token_TTL_Hours__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *token*, but the field is a Number: the ceiling, in hours, on how long a donor-portal session may live before the donor must sign in again. It is a configuration value an administrator sets; it contains no token.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** A number of hours — the ceiling on a donor-portal session's lifetime.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

86. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/SETTINGS__C/FIELDS/PORTAL_TOKEN_TTL_HOURS__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Portal_Token_TTL_Hours__c</fullName>
   4   <inlineHelpText>The absolute limit on how long a donor-portal session can last, in
hours, no matter how active the donor is. Leave blank for the 4-hour default. Capped at 168 (7
days) so a mis-set value can't make a session effectively permanent.</inlineHelpText>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

87. Vulnerability Name

ProtectSensitiveData — objects/Settings__c/fields/Soft_Credit_Automation_Enabled__c.field-meta.xml:1
(R-021; pmd, Moderate; False positive)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

88. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

89. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Soft_Credit_Automation_Enabled__c is a potential auth token in the object: Settings__c with public visibility — reported by ProtectSensitiveData (pmd, Moderate) at
objects/Settings__c/fields/Soft_Credit_Automation_Enabled__c.field-meta.xml:1

WHY THE CLAIM IS FALSE

The claim that this field "is a potential auth token" is false: the rule matched on *credit*, which here is the fundraising term soft credit (crediting a second person for influencing a gift), not a payment card. The field is a Checkbox that turns the soft-credit rollup on or off. A feature toggle is not a secret.

SUPPORTING DETAIL

Field names that merely contain sign, auth, token or credit. These fields match on a substring of an ordinary English word and carry nothing sensitive. Designation__c and Default_Designation__c (the fund a gift is earmarked for) and Campaign_Design__c.Theme_Tokens_JSON__c match on *sign* and *token* — one is a lookup to a program, the other is a JSON map of CSS design-token overrides that the service layer filters against a packaged catalog. Email_Signature__c is the sign-off line printed on outbound email. Re_Auth_Required__c and Re_Auth_Link_Sent_At__c match on *auth* and are a checkbox and a timestamp recording that a donor must complete 3-D Secure on-session for a renewal and when they were last reminded. Portal_Token_TTL_Hours__c is a number of hours. Soft_Credit_Automation_Enabled__c matches on *credit* and is a feature toggle for soft-credit rollups; it has nothing to do with a payment card. A Protected Custom Setting could not hold any of them: they are per-record business data, and the two on Settings__c are admin-visible configuration that the Settings console edits.

- **At this site:** Feature toggle for soft-credit rollups; matches on *credit*.
- **What the rule checks:** PMD's ProtectSensitiveData (AppExchange rule set) flags a custom field whose API name matches a list of sensitive-looking substrings, and asks that such data be stored in Protected Custom Settings or Protected Custom Metadata instead.

SOURCES

- Code Analyzer's own rule definition (AppExchange_xml.xml inside the bundled sfca-pmd-rules jar, class com.salesforce.security.pmd.xml.DetectSecretsInCustomObjects): the rule message is "To store secrets, use Protected Custom settings or Protected Custom metadata." It is keyed on the field's API name, which is why an ordinary word that contains *sign*, *auth*, *token* or *credit* is reported with the message "is a potential auth token".
- <https://trailhead.salesforce.com/content/learn/modules/secure-secrets-storage/protect-secrets-using-platform-features> — the Trailhead module the rule description refers to; it defines the remediation as storing "API keys or other secret keys" in protected custom met

adata or protected custom settings. None of these fields holds a key.

- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#protectsensitivedata> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- base/main/default/objects/<Object>/fields/<Field>.field-meta.xml — each flagged field's <description> and <inlineHelpText> state what it holds.

90. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — OBJECTS/SETTINGS__C/FIELDS/SOFT_CREDIT_AUTOMATION_ENABLED__C.FIELD-META.XML:1

```
» 1 <?xml version="1.0" encoding="UTF-8"?>
   2 <CustomField xmlns="http://soap.sforce.com/2006/04/metadata">
   3   <fullName>Soft_Credit_Automation_Enabled__c</fullName>
   4   <description>Controls whether finalized gifts get their soft credit worked out
automatically from the tribute honoree and the donor's household. Switched on for orgs installing
this package for the first time, since soft credit only ever fills fields that are otherwise empty
and never alters the donor of record or the amount. An org upgrading into the feature starts
switched off, because the package will not turn on a new automatic write in an org that already has
its own configuration.</description>
```

EVIDENCE CHECKED

Each field's <description> in base/main/default/objects/ says what it holds. The package stores no secret in any Custom Setting, protected or not — the org-wide credentials live only in Named Credentials (FP-4 in docs/security/appexchange-security-review-readiness.md), which is what the rule's remediation is for.

91. Vulnerability Name

LoadJavaScriptHtmlScript — `pages/stripePayment.page:53` (R-022; pmd, High; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

92. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors

AppExchange + Recommended:Security, configuration `code-analyzer.yml`, target `base/`; 23 findings across 3 rules; source commit 36949d12.

93. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Javascript should always be loaded from static resources — reported by LoadJavaScriptHtmlScript (pmd, High) at `pages/stripePayment.page:53`

WHY THE CLAIM IS FALSE

The claim that this script must be loaded from a static resource is false because Stripe forbids it: Stripe's integration documentation requires Stripe.js to be loaded directly from `https://js.stripe.com` and never bundled or self-hosted. The library is what keeps card data out of the merchant's origin, which is the basis of the package's PCI SAQ A eligibility, and Stripe patches it in place without a version change; a copy frozen into a static resource would be a payment library that is out of date the day the package is built and would void that eligibility. The page exists only to host the Stripe Payment Element in an iframe, the host `js.stripe.com` is declared as a packaged CSP trusted site, and the tag is preceded by a comment that states this reason. No Lightning Web Component in the package loads any external script.

SUPPORTING DETAIL

Stripe.js loaded from js.stripe.com in the two Visualforce payment pages. Stripe.js is the one script that cannot be bundled. Stripe requires it to be loaded from `https://js.stripe.com/v3/` at page load and forbids self-hosting, because the library is what keeps card data out of the merchant's origin (PCI DSS SAQ A eligibility) and Stripe patches it in place without a version change. Loading a frozen copy would ship a payment library that is out of date the day it is built. The package confines the load to exactly these two Visualforce pages, which exist only to host the Payment Element in an iframe and to receive the 3-D Secure / bank-authentication redirect; no Lightning Web Component loads any external JavaScript or CSS.

- **At this site:** `<script src="https://js.stripe.com/v3/">` on the iframe host page for the Payment Element.
- **What the rule checks:** PMD's LoadJavaScriptHtmlScript (AppExchange rule set) flags a `<script src>` that points at an external host. The review expects JavaScript to ship inside the package as a static resource, so that the code Salesforce reviewed is the code that runs.

SOURCES

- <https://docs.stripe.com/js/including> — "Include the Stripe.js script on each page of your site—it should always be loaded directly from <https://js.stripe.com>, rather than included in a bundle or hosted yourself."
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#loadjavascripthtmlscript> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- `base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml` — `js.stripe.com` is a packaged CSP trusted site, so the load is declared to the platform rather than slipped past it.

- docs/security/appexchange-security-review-readiness.md, FP-9 — the standing exception and its PCI reasoning.

94. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — PAGES/STRIPEPAYMENT.PAGE:53

```
50      supported evergreen version and receives security fixes without a redeploy;
Stripe now
51      recommends the named version that matches the server's Stripe-Version (dahlia).
Static
52      markup, and js.stripe.com is a packaged CSP trusted site. -->
» 53      <script src="https://js.stripe.com/v3/"></script>
54      <style>
55      body { margin: 0; padding: 0; background: transparent; font-family: system-ui,
sans-serif; }
56      #payment-element { padding: 4px 0; }
```

EVIDENCE CHECKED

grep -rn 'loadScript\\|loadStyle' base/main/default/lwc returns nothing, and these two pages are the only <script src= in the package. js.stripe.com is a packaged CSP trusted site. The exception is written up as FP-9 in docs/security/appexchange-security-review-readiness.md, and the pages carry the reason in a comment beside the tag.

95. Vulnerability Name

LoadJavaScriptHtmlScript — pages/stripePaymentReturn.page:40 (R-023; pmd, High; Working as designed)

Meant for the Internal Salesforce Security Team

Final Comment from Salesforce Team	
Date of Review (YYYY-MM-DD)	
Result	

96. Detected By

- ☐ Chimera
- ☒ PMD
- ☐ Security Review
- ☐ Others,

If case of others Please provide details : Salesforce Code Analyzer 0.53.0, engine pmd 0.46.0, rule selectors AppExchange + Recommended:Security, configuration code-analyzer.yml, target base/ ; 23 findings across 3 rules; source commit 36949d12.

97. Detailed explanation for considering False Positive (Elaborate as much as possible)

SCANNER'S CLAIM

Javascript should always be loaded from static resources — reported by LoadJavaScriptHtmlScript (pmd, High) at pages/stripePaymentReturn.page:40

WHY THE CLAIM IS FALSE

The claim is false for the same reason: Stripe requires Stripe.js to be loaded from <https://js.stripe.com> and forbids self-hosting. This page is the return target of a 3-D Secure or bank-authentication redirect and must call Stripe.js to read the redirect result; it has no other content. The host is a packaged CSP trusted site, the reason is written in a comment beside the tag, and no other `<script src>` exists in the package.

SUPPORTING DETAIL

Stripe.js loaded from js.stripe.com in the two Visualforce payment pages. Stripe.js is the one script that cannot be bundled. Stripe requires it to be loaded from <https://js.stripe.com/v3/> at page load and forbids self-hosting, because the library is what keeps card data out of the merchant's origin (PCI DSS SAQ A eligibility) and Stripe patches it in place without a version change. Loading a frozen copy would ship a payment library that is out of date the day it is built. The package confines the load to exactly these two Visualforce pages, which exist only to host the Payment Element in an iframe and to receive the 3-D Secure / bank-authentication redirect; no Lightning Web Component loads any external JavaScript or CSS.

- **At this site:** Same tag on the 3-D Secure / bank-authentication return page, which must call Stripe.js to read the redirect result.
- **What the rule checks:** PMD's LoadJavaScriptHtmlScript (AppExchange rule set) flags a `<script src>` that points at an external host. The review expects JavaScript to ship inside the package as a static resource, so that the code Salesforce reviewed is the code that runs.

SOURCES

- <https://docs.stripe.com/js/including> — "Include the Stripe.js script on each page of your site—it should always be loaded directly from <https://js.stripe.com>, rather than included in a bundle or hosted yourself."
- <https://developer.salesforce.com/docs/platform/salesforce-code-analyzer/guide/rules-pmd-appexchange.html#loadjavascripthtmlscript> — the scanner's reference for this rule (page could not be retrieved while this document was prepared: the host answers automated requests with HTTP 403, so it is cited as the scanner's own reference link and not quoted).
- [base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml](#) — js.stripe.com is a packaged CSP trusted site, so the load is declared to the platform rather than slipped past it.
- [docs/security/appexchange-security-review-readiness.md](#), FP-9 — the standing exception and its PCI reasoning.

98. Evidence (screenshots of the code, implementation, Command Output)

FLAGGED CODE — PAGES/STRIPEPAYMENTRETURN.PAGE:40

```
37      supported evergreen version and receives security fixes without a redeploy;
Stripe now
38      recommends the named version that matches the server's Stripe-Version (dahlia).
Static
39      markup, and js.stripe.com is a packaged CSP trusted site. -->
» 40      <script src="https://js.stripe.com/v3/"></script>
41      <style>
42          * { box-sizing: border-box; margin: 0; padding: 0; }
43      body {
```

EVIDENCE CHECKED

`grep -rn 'loadScript\\|loadStyle' base/main/default/lwc` returns nothing, and these two pages are the only `<script src=` in the package. `js.stripe.com` is a packaged CSP trusted site. The exception is written up as FP-9 in docs/security/appexchange-security-review-readiness.md, and the pages carry the reason in a comment beside the tag.

Appendix A — scan summary and every reported finding

Scanner	Salesforce Code Analyzer 0.53.0 (sf code-analyzer run)
Engines	retire-js 0.39.0, regex 0.40.0, eslint 0.47.0, pmd 0.46.0
Rule selectors	AppExchange + Recommended:Security — the security-review command
Configuration	code-analyzer.yml at the repository root (custom PMD rulesets and the ESLint options file it names; no rule is disabled)
Target	base/ — the whole packaged source
Findings reported	23 across 3 rules, every one answered above
Source commit	36949d12
Prepared	2026-10-09

The verdicts are the ones CI enforces: the project keeps them in `scripts/lint/analyzer-exceptions.json`, a build step fails on any High or security-tagged finding with no verdict and on any verdict whose finding no longer exists, and the docs site publishes the same record.

Rule	Engine	Severity	Findings	False positive	Working as designed	Third-party
ApexDangerousMethods	pmd	Moderate	3	0	3	0
ProtectSensitiveData	pmd	Moderate	18	10	8	0
LoadJavaScriptHtmlScript	pmd	High	2	0	2	0
Total			23	10	13	0

Rule	Engine	Sev.	File:line	Message	Entry	Verdict
ApexDangerousMethods	pmd	Moderate	base/main/default/classes/donation/domain/DonationDesignations.cls:36	Calling potentially dangerous method	R-001 (Q7)	Working as designed
ApexDangerousMethods	pmd	Moderate	base/main/default/classes/donor/domain/Contacts.cls:52	Calling potentially dangerous method	R-002 (Q11)	Working as designed
ApexDangerousMethods	pmd	Moderate	base/main/default/classes/recurring/domain/RecurringDonations.cls:61	Calling potentially dangerous method	R-003 (Q15)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Campaign_Design__c/fields/Theme_Tokens_JSON__c.field-meta.xml:1	Theme_Tokens_JSON__c is a potential auth token in a custom object: Campaign_Design__c	R-004 (Q19)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Donation_Designation__c/fields/Designation__c.field-meta.xml:1	Designation__c is a potential auth token in a custom object: Donation_Designation__c	R-005 (Q23)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Donation_Staging__c/fields/Access_Token__c.field-meta.xml:1	Access_Token__c is a potential auth token in a custom object: Donation_Staging__c	R-006 (Q27)	Working as designed

Rule	Engine	Sev.	File:line	Message	Entry	Verdict
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Donation_Staging__c/fields/Idempotency_Key__c.field-meta.xml:1	Idempotency_Key__c is a potential auth token in a custom object: Donation_Staging__c	R-007 (Q31)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Guest_Request__c/fields/Idempotency_Key__c.field-meta.xml:1	Idempotency_Key__c is a potential auth token in a custom object: Guest_Request__c	R-008 (Q35)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Payment_Account__c/fields/Publishable_Key__c.field-meta.xml:1	Publishable_Key__c is a potential auth token in a custom object: Payment_Account__c	R-009 (Q39)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Payment_Account__c/fields/Stripe_Admin_Restricted_Key__c.field-meta.xml:1	Stripe_Admin_Restricted_Key__c is a potential auth token in a custom object: Payment_Account__c	R-010 (Q43)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Payment_Account__c/fields/Stripe_Donor_Restricted_Key__c.field-meta.xml:1	Stripe_Donor_Restricted_Key__c is a potential auth token in a custom object: Payment_Account__c	R-011 (Q47)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Portal_Access_Token__c/fields/Code_Hash__c.field-meta.xml:1	Code_Hash__c is a potential auth token in a custom object: Portal_Access_Token__c	R-012 (Q51)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Portal_Access_Token__c/fields/Session_Hash__c.field-meta.xml:1	Session_Hash__c is a potential auth token in a custom object: Portal_Access_Token__c	R-013 (Q55)	Working as designed
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Recurring_Designation__c/fields/Designation__c.field-meta.xml:1	Designation__c is a potential auth token in a custom object: Recurring_Designation__c	R-014 (Q59)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Recurring_Donation__c/fields/Designation__c.field-meta.xml:1	Designation__c is a potential auth token in a custom object: Recurring_Donation__c	R-015 (Q63)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Recurring_Donation__c/fields/Re_Auth_Link_Sent_At__c.field-meta.xml:1	Re_Auth_Link_Sent_At__c is a potential auth token in a custom object: Recurring_Donation__c	R-016 (Q67)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Recurring_Donation__c/fields/Re_Auth_Required__c.field-meta.xml:1	Re_Auth_Required__c is a potential auth token in a custom object: Recurring_Donation__c	R-017 (Q71)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Settings__c/fields/Default_Designation__c.field-meta.xml:1	Default_Designation__c is a potential auth token in the object: Settings__c with public visibility	R-018 (Q75)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Settings__c/fields/Email_Signature__c.field-meta.xml:1	Email_Signature__c is a potential auth token in the object: Settings__c with public visibility	R-019 (Q79)	False positive

Rule	Engine	Sev.	File:line	Message	Entry	Verdict
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Settings__c/fields/Portal_Token_TTL_Hours__c.field-meta.xml:1	Portal_Token_TTL_Hours__c is a potential auth token in the object: Settings__c with public visibility	R-020 (Q83)	False positive
ProtectSensitiveData	pmd	Moderate	base/main/default/objects/Settings__c/fields/Soft_Credit_Automation_Enabled__c.field-meta.xml:1	Soft_Credit_Automation_Enabled__c is a potential auth token in the object: Settings__c with public visibility	R-021 (Q87)	False positive
LoadJavaScriptHtmlScript	pmd	High	base/main/default/pages/stripePayment.page:53	Javascript should always be loaded from static resources	R-022 (Q91)	Working as designed
LoadJavaScriptHtmlScript	pmd	High	base/main/default/pages/stripePaymentReturn.page:40	Javascript should always be loaded from static resources	R-023 (Q95)	Working as designed